

CITY UNIVERSITY OF HONG KONG

Course code & title : CS5285 Information Security for eCommerce

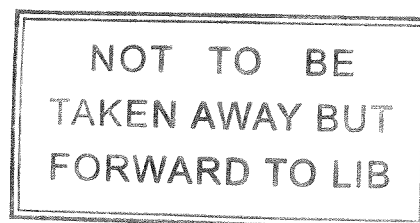
Session : Semester A 2009/10

Time allowed : Two hours

This paper has SEVEN pages (including this cover page).

1. This paper consists of 9 questions.
 2. Answer ALL NINE questions.
 3. Total: 100 points
 4. This is a close-book examination: students should not bring any book, lecture or tutorial note; problem set solution or any other related paper or printout
 5. Calculators: only HKEA approved ones
-

NOT TO BE TAKEN AWAY



Remark: Give concise reasons and show key steps in each problem. Keep your answers and reasons brief and right-to-the-point.

1. Symmetric Key Cryptography (15 points)

(a) (5 points)

Draw a diagram to illustrate the Feistel transformation. In your diagram, use L_0 and R_0 to denote the left block and right block of the input, respectively, and L_1 and R_1 to denote the left block and right block of the output, respectively. Use K_1 to denote the round key and f to denote the round function.

(b) (5 points)

By launching brute-force attack against DESX, estimate in seconds the average time required for finding the key (K_1, K_2, K_3). Suppose that the attacker has a frame of 5760 chips, each chip can try 10^{12} DESX keys per second independently.

(c) (5 points)

If we know that an attacker is able to try 10^{20} keys of an encryption algorithm per second, determine the minimum key length in order to make sure that on average the attacker has to spend more than 100 years before finding the key.

2. Symmetric Key Cryptography (10 points)

(a) (5 points)

Name four block cipher algorithms. Give one advantage of using block cipher over stream cipher.

(b) (5 points)

If AES is used, for each of the applications below, identify the most suitable operation mode and use at most two sentences to explain why the other two operation modes are not desirable. Operation modes to choose from are ECB, CBC and CTR.

1. Building a Message Authentication Code (MAC);
2. Encrypting a hard-disk in which data have to be updated arbitrarily;
3. Encrypting an 80-bit session key and transmitting it over a low bandwidth communication channel, for example satellite communications.

3. Public Key Encryption (19 points)

(a) (5 points)

Let $p=13$ and $g=2$. Find the discrete logarithms a and b such that $11 = g^a \bmod p$ and $7 = g^b \bmod p$.

(b) (10 points)

Let the RSA public modulus $n = pq = 77$. Find the smallest possible RSA public exponent e . Now if $e = 13$, find the corresponding RSA private exponent d .

(c) (4 points)

For each of the algorithms below, name the underlying mathematical assumption that the algorithm's security is relying on.

1. ElGamal Encryption

2. RSA Encryption

3. Diffie-Hellman Key Exchange

4. Digital Signature and Hash Function (10 points)

(a) (2 points)

Find out the expected number of messages that a bruteforce attacker has to try in order to break the strong collision resistance of MD5. Represent your result in 2's power.

(b) (3 points)

Draw a diagram to show how an AES-CBC based MAC works. In your diagram, use (m_1, m_2, m_3) to represent the three blocks of a message, T to represent the MAC tag and K to represent the key.

(c) (5 points)

Let $H(x) = g^x \bmod p$. Use at most 4 statements to show that H does not satisfy weak collision resistant nor strong collision resistant. If $H(x) = 3^x \bmod 7$, find two distinct inputs x and y such that $H(x) = H(y)$ and the values of x and y must be greater than 20.

5. Public Key Infrastructure and Trust Models (8 points)

(a) (3 points)

For each of the scenarios below, determine which PKI (Public Key Infrastructure) trust model is the most suitable one and use at most two sentences to explain each of your answers. The three types of trust models are Monopoly, Anarchy and Oligarchy.

1. A web browser for accessing secure web servers on the Internet.
2. A small group of computer scientists who want to exchange free but secure emails with one another within the group only.
3. A highly secure system used only internally within a university.

(b) (2 points)

In PGP, suppose that a public key is considered **legitimate** only if $X=3$ “trusted” signatures or $Y=5$ “usually trusted” signatures are collected. Determine if Bob’s public key should be considered legitimate if 2 “trusted” signatures and 2 “usually trusted” signatures have been collected for it.

(c) (3 points)

If a digital certificate needs to be revoked, describe the two steps that the corresponding CA (Certification Authority) has to do.

6. Mutual Authentication and Key Establishment (8 points)

(a) (4 points)

Let p be a prime and g a generator in the Diffie-Hellman key exchange. Draw a diagram to illustrate how the Diffie-Hellman works and specify how the session key is computed. Let the session key be K . Then draw another protocol diagram to illustrate how an attacker Trudy can compromise the protocol and specify the name of the attack.

(b) (4 points)

Suppose that Alice and Bob share a long-term symmetric key K and they do not have any public key. Describe four different types of symmetric key based challenge-response protocols, each of them allows Bob to authenticate Alice. You are not allowed to use timestamp.

7. SSL, IPSec and IKE (13 points)

(a) (3 points)

Let (n, e) be the RSA public key and d the RSA private key. To protect every single bit of a message m , SSL protocol encrypts m using an algorithm similar to the following.

1. Pick a random number r
2. Compute the ciphertext $c = (m \oplus G(r) \parallel r \oplus H(m \oplus G(r)))^e \bmod n$

where G and H are hash functions and ' $\parallel$ ' denotes binary string concatenation. Describe the decryption algorithm. In your answer, use at most two sentences to describe each step. (Hint: there are three steps.)

(b) (2 points)

Name two properties of the IKE Phase 1, Signature Based (Main Mode) that are not supported by the IKE Phase 1, Signature Based (Aggressive Mode).

(c) (2 points)

Identify what mode(s) of IPSec can be used for each of the following types of connections.

- (1) Host-to-host
- (2) Host-to-gateway
- (3) Gateway-to-gateway

(d) (3 points)

List all the IKE Phase 1 variants that support anonymity.

(e) (3 points)

If only Transport mode can be used, show the encapsulation structure of an IP datagram if the IP data need to be encrypted and the entire IP datagram other than the mutable IP header fields should be authenticated.

8. Firewall, Network Security and Computer Security (9 points)

(a) (3 points)

Construct an Access Control List (ACL) such that the packet filtering firewall only allows company employees to access secure web servers on the Internet and insecure web servers as well as SSH (secure shell) hosts within the company network but nothing else. Assume that the port numbers of SSL and HTTP are 443 and 80, respectively, and that of SSH is 22. Your ACL should only contain at most four rows.

(b) (1 point)

If the number of hops between the adversary's machine and a stateful packet filter is 5. What value of TTL should the adversary set for launching Firewalk?

(c) (2 points)

Give one difference between worm and bacteria; give one difference between virus and worm.

(d) (3 points)

For each user in a system, the system's password file stores a pair of (y, s) for the user where y is computed as follows and s is a salt. Determine which of the following methods of computing y are secure against (precomputed) dictionary attack. Assume that s is 40 bits long and randomly chosen.

1. $y = H(\text{password}, s)$ where H is SHA-1
2. $y = H(s) \oplus \text{password}$
3. $y = H(s) \oplus H(\text{password})$
4. $y = E(s, \text{password})$ where E is AES and the first input is the key
5. $y = E(\text{password}, s)$
6. $y = E(s, H(\text{password}))$
7. $y = \text{MAC}(s, \text{password})$ where MAC is HMAC and the first input is the key
8. $y = \text{MAC}(\text{password}, s)$

9. Wireless Security (8 points)

(a) (2 points)

In GSM authentication, identify which of the following parties know the user key K_i .

- (1) User's SIM card
- (2) AuC
- (3) Base Station
- (4) Base Station controller

(b) (2 points)

In GSM authentication, $SRES$ is only 32 bits long while $RAND$ is 128 bits long. Explain the purpose of $SRES$. Also find out the probability that an active adversary guesses the value of $SRES$ correctly.

(c) (3 points)

Name three security objectives that are common to both GSM and 3GPP.

(d) (1 point)

Name the algorithm that the WEP uses for message authentication.

- End -